



DECLARACIÓN DE APLICABILIDAD

Versión:	0.10
Fecha de la versión:	21/11/2025
Creado por:	Ana Karim Salazar
Aprobado por:	Milton Guevara
Nivel de confidencialidad:	Restringida

Historial de modificaciones

Fecha	Versión	Creado por	Descripción de la modificación
18-11-2019	0.1	Ana Karim Salazar	Versión inicial del documento
29-11-2019	0.2	Ana Karim Salazar	Se retiraron controles que no son aplicables para el alcance del SGSI. Los controles son los del grupo A.14.2 y A.14.3, además del control A.9.4.4
30/09/2020	0.3	Ana Karim Salazar	Se cambió el estado de los controles que estaban en "Parcialmente implementado" a "Totalmente implementado". En el método de implementación de algunos controles se complementó con Política sobre dispositivos móviles y de Tele – trabajo, Política trae tu propio dispositivo (BYOD), Registro de Banco de datos y Licencia de funcionamiento.
04/03/2021	0.4	Ana Karim Salazar	Actualización del rol Asistente administrativo "contable" En A.6.2.2 de: Necesario para las laptops de consultoría y las computadoras involucradas en el plan de recuperación. a: Todos los dispositivos con inscripción Autopilot En A.7.2.3 Proceso disciplinario , se agrega Reglamento interno. En A.9.2.1 Registro de usuarios y baja , se agrega Acta de devolución de materiales, suministros y accesos. En A.9.4.4 Uso de programas de utilidad privilegiada , pasa de NO a SI "Exigido para controlar el riesgo de posibles daños, sólo el administrador de sistemas tendrá acceso a programas de sistemas con privilegios especiales." En A.11.1.4 Protección ante amenazas externas y ambientales , se agrega "Plan de recuperación ante desastres en Oficina" En A.12.4.2 Protección de la información del registro , se agrega Política de control de accesos. En A.12.6.1 Gestión de vulnerabilidades técnicas , se agrega "Procedimiento para cambios críticos" Implementación de los objetivos A.14.2 (excepto A.14.2.3 y A.14.2.7) y A.14.3
10/09/2021	0.5	Ana Karim Salazar	Cambios ubicados en el Repositorio de documentos online de Siempresoft /02 -Área de Seguridad de la Información / Anexos /Anexo N°5.pdf
20/12/2021	0.6	Ana Karim Salazar	Cambios ubicados en el Repositorio de documentos

			online de Siempresoft /02 -Área de Seguridad de la Información / Anexos /Anexo N°6.pdf
15-11-2022	0.7	Ana Karim Salazar	Ampliación de fecha de vigencia
23-08-2023	0.8	Ana Karim Salazar	Cambios ubicados en el Repositorio de documentos online de Siempresoft /02 -Área de Seguridad de la Información / Anexos /Anexo N°16.pdf
22-11-2024	0.9	Ana Karim Salazar	Incorporación de Métodos de implementación de los controles: A.5.8. Seguridad de la información en gestión de proyectos: Manual de Migración del Sistema SIEMPRESOFT ERP a PaaS A.6.3. Toma de conciencia, educación y entrenamiento sobre la seguridad de la información: Procedimiento de medición del rendimiento del colaborador
21-11-2025	0.10	Ana Karim Salazar	3. Aplicabilidad de los controles Incorpora en los controles A.5.1: - Política de protección de datos personales A.5.8: - Evaluación de riesgos en los proyectos A.5.13: - Clasificación y detección de datos / Etiquetas de clasificación de confidencialidad (en SQL databases) A.5.34: - Política de protección de datos personales A.5.35: - Auditorias de ethical hacking a los sistemas de información (por una empresa externa) A.5.37: - Manual técnico del API PSE, Funcionamiento de arquitectura del API PSE A.6.2: - Código de conducta A.8.11 y 8.12: Política de protección de datos personales

Tabla de contenido

TABLA DE CONTENIDO	3
1. OBJETIVO, ALCANCE Y USUARIOS	4
2. DOCUMENTOS DE REFERENCIA.....	4
3. APLICABILIDAD DE LOS CONTROLES.....	4
4. ACEPTACIÓN DE LOS RIESGOS RESIDUALES.....	31
5. VALIDEZ Y GESTIÓN DE DOCUMENTOS	31

1. Objetivo, alcance y usuarios

El objetivo del presente documento es definir qué controles son adecuados para implementar en Siempresoft, cuáles son los objetivos de esos controles y cómo se implementan. También tiene como objetivo aprobar riesgos residuales y aprobar formalmente la implementación de los controles mencionados.

Este documento incluye todos los controles detallados en el Anexo A de la norma ISO 27001. Los controles se aplican a todo el alcance del Sistema de gestión de seguridad de la información (SGSI).

Los usuarios de este documento son todos empleados de Siempresoft que cumplen una función dentro del SGSI.

2. Documentos de referencia

- Norma ISO/IEC 27001, capítulo 6.1.3 d)
- NTP – ISO/IEC 27002:2022
- Política de seguridad de la información
- Metodología de evaluación y tratamiento de riesgos
- Informe de evaluación y tratamiento de riesgos

3. Aplicabilidad de los controles

Los controles seleccionados del Anexo A, para justificación de inclusión:

- Requerimientos Legales (RL): se implementa por regulaciones y leyes aplicables de la empresa.
- Obligaciones Contractuales (OC): se implementa debido a acuerdos con terceros, por medio de contratos, o especificaciones en los Acuerdos de Nivel de Servicio.
- Requerimientos del Negocio (RN): se implementa debido a requerimientos o exigencias del negocio.
- Buenas Prácticas (BP): se implementa como determinación de la empresa en la aplicación de buenas prácticas de seguridad.
- Resultados de la Evaluación de Riesgos (RER): se implementa a raíz de evaluaciones de riesgo siendo su implementación necesaria para reducir el riesgo a niveles aceptables.

Son aplicables los siguientes controles del Anexo A de la norma ISO 27001:

ID	Controles de norma ISO/IEC 27001	Aplicabilidad (SÍ/NO)	Justificación de elección/no elección	Objetivos del control	Método de implementación	Estado
A.5	Controles organizacionales					
A.5.1	Políticas para la seguridad de la información	SÍ	Documento obligatorio que es necesario para la ISO 27001, es un documento de alto nivel que describe el propósito de la implementación y mantenimiento del SGSI y los objetivos de seguridad a cumplir. RL, RN	Disminuir la cantidad de documentos vencidos o sin control de cambios en el año.	Política de Seguridad de la Información Política Sobre Dispositivos Móviles y Teletrabajo Política de Eliminación y Destrucción Política de Clasificación de la Información Política de Uso Aceptable Política de Control de Acceso Política de Claves Política de Uso de Controles Criptográficos Política de Pantalla y Escritorio Limpios Política de Creación de Copias de Seguridad Política de Gestión de Cambio Política de Desarrollo Seguro Política de Transferencia de Información Política de Seguridad para Proveedores Política de protección de datos personales	Totalmente implementado
A.5.2	Roles y responsabilidades en seguridad de la información	SÍ	Documento obligatorio que es necesario para la ISO 27001 que describe los roles y responsabilidades en cada una de las políticas y procedimientos; y de manera general en los perfiles de puesto. RL, OC, RN	Disminuir la cantidad de responsabilidades que no han sido comunicadas al propietario para la protección de activos, riesgos y procesos específicos de seguridad de la información en el año.	Política de Seguridad de la Información - numeral 4.5. Responsabilidades, 4.7. Segregación de funciones Perfiles de Puesto. Metodología de evaluación y tratamiento de riesgos numeral 3.5. Seguimiento y revisión Manual del SGSI - numeral 5.3 Autoridades, roles y responsabilidades. Reglamento interno de trabajo	Totalmente implementado

A.5.3	Segregación de funciones	Sí	Prevenir que el colaborador ejecute por sí mismo funciones potencialmente conflictivas. RN, BP, RER	Reducir la cantidad de solicitudes de correo críticas ejecutadas sin ser aprobadas en el año.	Política de seguridad de la información apartado 4.5. Responsabilidades y 4.7. Segregación de funciones Manual del SGSI 5.3. Autoridades, roles y responsabilidades Política de gestión de cambio 3. Gestión de cambios, Política de control de accesos 3.4. Gestión de privilegios, Instructivo para buen uso de Team Explorer, numerales Acciones permitidas en ramas y Protección y comentarios en ramas, Registro de accesos Perfiles de puesto	Totalmente implementado
A.5.4	Responsabilidades de la dirección	Sí	Asegurar que todo el personal conozca y sus responsabilidades de seguridad de la información para el buen desempeño del SGSI. RL, RN	Reducir compromisos incumplidos por la Alta gerencia en el año.	Responsabilidad de la Alta Gerencia, Política de Seguridad de la Información numeral 4.5. Responsabilidades, Manual del SGSI apartado 5.3. Autoridades, roles y responsabilidades y 7.2. Competencia, consciencia y capacitación	Totalmente implementado
A.5.5	Contacto con autoridades	Sí	Asegurar el flujo de información y reportes de incidentes de seguridad de la información a las autoridades externas. RN, RER	Disminuir la cantidad de números de emergencia desactualizados en el año.	Números de emergencias Registro Autorización de comunicación con las partes interesadas	Totalmente implementado

A.5.6	Contacto con grupos especiales de interés	Sí	Asegurar el flujo de información u otros foros de especialistas en seguridad. RN, RER	Obtener mayor cobertura de contactos de grupos de interés que apoyen en la seguridad de la información en el año.	Números de Grupos Especiales de Interés	Totalmente implementado
A.5.7	Inteligencia de amenazas	Sí	Requisito obligatorio para recopilar y analizar la información, y producir inteligencia sobre amenazas de seguridad de la información. RL, OC, RN, BP, RER	Tomar acciones de mitigación adecuada para actuar de manera inmediata a las amenazas y vulnerabilidades detectadas al año.	Procedimientos Operativos para TI y de la Comunicación numeral 3.12. Gestión de amenazas y vulnerabilidades técnicas Microsoft defender for cloud (Posición de seguridad) Microsoft 365 defender (Inteligencia de amenazas)	Totalmente implementado
A.5.8	Seguridad de la información en gestión de proyectos	Sí	Garantizar que los riesgos de seguridad de la información se aborden de manera efectiva en la gestión de proyectos. OC, RN, BP, RER	Abordar los riesgos de seguridad desde las primeras etapas del ciclo de vida de la gestión de proyectos en el año.	Procedimiento para implantación de sistema SIEMPRESOFT ERP Procedimientos operativos para tecnología de la información y de la comunicación apartado 3.11. Gestión de la capacidad Procedimiento de despliegue de NUEVA VERSION del Sistema SIEMPRESOFT Manual de Migración del Sistema SIEMPRESOFT ERP a PaaS	Totalmente implementado
A.5.9	Inventario de información y otros activos asociados	Sí	Documento obligatorio que es necesario para la ISO 27001 donde deben estar identificados todos los activos y sus propietarios. RL, RN	Reducir la cantidad de activos de los procesos de negocio que no están incluidos o desactualizados en el año.	Inventario de activos Política de clasificación de la información	Totalmente implementado

A.5.10	Uso aceptable de la información y otros activos asociados	Sí	Documento obligatorio que es necesario para la ISO 27001 para asegurar que la información y activos asociados son protegidos y utilizados de manera apropiada. RL, RN, BP, RER	Disminuir la detección de actividades prohibidas en los activos de información en un 30% en el año.	Política de uso aceptable Procedimiento para control de documentos y registros apartado 5. Documentos externos Declaración de Confidencialidad Proveedores, Acuerdos con proveedores de servicios en la nube	Totalmente implementado
A.5.11	Devolución de activos	Sí	Proteger los activos en el cambio o terminación del contrato con trabajadores y proveedores. RL, OC, RN, RER	Garantizar la devolución de los activos al finalizar el contrato al 100% en el año.	Procedimiento para Terminación o cambio de puesto Política de uso aceptable apartado 3.7 Devolución de activos a la finalización de un contrato Política de seguridad para proveedores, Acta de devolución de activos	Totalmente implementado
A.5.12	Clasificación de la información	Sí	Asegurar la protección de la información de acuerdo a su valor, criticidad, y sensibilidad frente a la divulgación o modificación no autorizada. RL, RN, RER	Garantizar que toda la información sensible sea clasificada en el año.	Política de clasificación de la información apartado 3.2. Clasificación de la información Inventario de activos	Totalmente implementado
A.5.13	Etiquetado de la información	Sí	Facilitar el sistema de etiquetado para proteger la información sensible según el medio de almacenamiento. RL, RN, BP, RER	Reducir la cantidad de activos de información que no cuenten con el nivel de etiquetado adecuado en el año.	Política de clasificación de la información apartado 3.3 Etiquetado de la información Etiquetados para puntos de conexión con Microsoft Purview (Protección de información)	Totalmente implementado

A.5.14	Transferencia de información	Sí	Mantener la seguridad de la información del mal uso o la corrupción durante el transporte. RL, OC, RN, BP, RER	Reducir incidente por exposición de la información sensible al momento de ser transferida en el año.	Política de clasificación de la información apartado 3.4 Manejo de información clasificada Política de transferencia de la Información apartado 3. Transferencia de la información Política de uso aceptable apartado 3.13. Correo electrónico y otros métodos de intercambio de mensajes	Totalmente implementado
A.5.15	Control de acceso	Sí	Documento obligatorio que es necesario para la ISO 27001 que tiene como propósito asegurar el acceso autorizado y prevenir el acceso no autorizado a la información del negocio. RL, OC, RN, BP, RER	Reducir la cantidad de incidencias por accesos no autorizados a la información en el año.	Política de control de accesos Registro de accesos Acta de asignación de derechos	Totalmente implementado
A.5.16	Gestión de identidades	Sí	Permitir la identificación única y asignación adecuada de derechos de accesos de usuarios y sistemas que interactúan con los activos e información de la organización OC, RN, BP, RER	Reducir eventos relacionados con la mala gestión de identidades de los usuarios en el año.	Política de control de accesos apartado 3.6 Gestión de cuentas de usuario Política de claves apartado 3. Gestión de identidades	Totalmente implementado

A.5.17	Información de autenticación	Sí	Mantener confidencial la entrega de la información de autenticación secreta, debe ser controlada a través de un proceso de gestión formal. RL, OC, RN, BP, RER	Reducir la cantidad de incidentes relacionado con la identificación secreta de los usuarios en el año.	Política de claves apartado 5. Gestión de la clave del usuario Compromiso de no divulgación Declaración de aceptación de documentos del SGSI	Totalmente implementado
A.5.18	Derechos de acceso	Sí	Asegurar que el acceso a la información y activos deben ser controlados por un proceso formal de autorización de acuerdo a los requisitos del negocio. RL, OC, RN, BP, RER	Disminuir la cantidad de procesos de autorización incompletas a los derechos de acceso de usuario en el año.	Política de control de acceso	Totalmente implementado
A.5.19	Seguridad de la información en las relaciones con los proveedores	Sí	Documento obligatorio que es necesario para la ISO 27001, y mantener la seguridad de la información con los proveedores mediante acuerdos y contratos. RL, OC, RN, BP, RER	Reducir la selección inadecuada de un proveedor antes de contratar u producto / servicio en el año.	Política de seguridad para proveedores Apéndice Clausulas de seguridad para proveedores y socios Declaración de Confidencialidad de Proveedores	Totalmente implementado
A.5.20	Abordar la seguridad de la información dentro de los acuerdos con proveedores	Sí	Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores. RL, OC, RN, RER	Supervisar el cumplimiento de las cláusulas de seguridad en todos los proveedores en el año.	Contrato con proveedores Declaración de Confidencialidad de Proveedores	Totalmente Implementado

A.5.21	Gestión de la seguridad de la información en la cadena de suministro de las tecnologías de la información y comunicación (TIC)	Sí	Abordar la seguridad de la información dentro de la cadena de suministros de Tecnologías de la Información y la Comunicación en los sistemas SIEMPRESOFT ERP y SIEMPRESOFT OSE. OC, RN, RER	Reducir las veces que no se ha evaluado la seguridad de la información en la cadena de suministros de TIC antes de contratar un producto/servicio en el año.	Política de seguridad para proveedores Declaración de confidencialidad de Proveedor Procedimientos Operativos para TI y de la Comunicación	Totalmente implementado
A.5.22	Seguimiento, revisión y gestión de cambios en servicios de proveedores	Sí	Monitorear que los cambios en seguridad de la información del proveedor no afecten a la prestación del servicio. RL, OC, RN, BP, RER	Reducir eventos ocurridos por cambios en la seguridad de los proveedores que afecten la continuidad del servicio en el año.	Política de seguridad para proveedores Control de monitoreo y revisión de los servicios de los proveedores	Totalmente implementado
A.5.23	Seguridad de la información en el uso de servicios en la nube	Sí	Documentar la selección, adquisición, uso y salida de los servicios en la nube y administrar la seguridad de la información definiendo las responsabilidades correspondientes. RL, OC, RN, BP, RER	Reducir contratos que no cuenten con disposiciones para la protección de los datos y disponibilidad de los servicios en el año.	Política de seguridad para proveedores Procedimientos operativos para tecnología de la información y de la comunicación apartado 3.13. Uso de servicios en la nube	Totalmente Implementado

A.5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	Sí	Documento obligatorio que es necesario para la ISO 27001 que busca garantizar una respuesta rápida a los incidentes de seguridad de la información y la comunicación sobre los eventos de seguridad. RL, OC, RN, RER	Lograr que los incidentes de seguridad de la información deben ser comprendidos de acuerdo con los procedimientos documentados al año.	Procedimiento para gestión de incidentes	Totalmente implementado
A.5.25	Evaluación y decisión sobre los eventos de seguridad de la información	Sí	Asegurar la categorización y priorización efectiva de los eventos de seguridad de la información. RL, OC, RN, RER	Reducir el mal manejo de incidentes de seguridad de la información por errores en la categorización en el año.	Procedimiento para gestión de incidentes	Totalmente implementado
A.5.26	Respuesta a incidentes de seguridad de la información	Sí	Asegurar una respuesta eficiente a los incidentes de seguridad de la información. RL, OC, RN, RER	Reducir las veces que un incidente de seguridad de la información no es respondido por el equipo designado con la competencia necesaria en el año.	Procedimiento para gestión de incidentes Procedimiento de Atención al Cliente	Totalmente implementado
A.5.27	Aprendizaje de los incidentes de seguridad de la información	Sí	Reducir la probabilidad de nuevas ocurrencias y las consecuencias de futuros incidentes similares o mayores. RN, BP, RER	Disminuir la recurrencia de incidentes de seguridad de la información que puedan generar consecuencias graves en el año.	Procedimiento para gestión de incidentes, Procedimiento para medidas correctivas	Totalmente implementado

A.5.28	Recolección de evidencia	Sí	Asegurar la manera como gestionar evidencias consistentes para efecto de acciones disciplinarias y legales. RL, OC, RN, BP, RER	Reducir la pérdida, destrucción intencional o accidental de evidencias de los incidentes de seguridad de la información en el año.	Procedimiento para gestión de incidentes Reglas para identificación, recolección y preservación de evidencia Procedimiento de Atención al Cliente Procedimientos operativos para tecnología de la información y de la comunicación	Totalmente implementado
A.5.29	Seguridad de la información durante una interrupción	Sí	Exigido ante un desastre y proteger la información con los activos asociados durante una interrupción. RL, OC, RN, BP, RER	Reducir las veces que no se realizan pruebas de los planes de recuperación ante desastres y de las TIC en las fechas planificadas.	Plan de recuperación ante desastre en oficina Plan de recuperación ante desastre en plataforma	Totalmente implementado
A.5.30	Preparación de las TIC para la continuidad del negocio	Sí	Exigido para continuar operando durante la situación de crisis manteniendo un nivel aceptable de seguridad de la información. RL, OC, RN, RER	Conseguir la recuperación de la continuidad de las TIC dentro de los tiempos de recuperación objetivo en el año	Plan de recuperación ante desastre en oficina Plan de recuperación ante desastre en plataforma	Totalmente implementado
A.5.31	Requisitos legales, estatutarios, regulatorios y contractuales	Sí	Documento obligatorio que es necesario para la ISO 27001, sirve de apoyo para identificar y cumplir con los requisitos legales, regulatorios, criptográficos y regulatorios como PSE y OSE. RL, OC, RN, RER	Evitar multas y sanciones por falta de revisión del cumplimiento de los requisitos legales y normativos en el año.	Lista de requisitos legales, normativos, contractuales y de otra índole Reglamento interno de trabajo	Totalmente implementado

A.5.32	Derechos de propiedad intelectual	Sí	Garantizar el cumplimiento de los requisitos legales relacionados con los derechos de propiedad intelectual y el uso de productos patentados por Siempresoft. RL, OC, RN, BP, RER	Evitar multas o sanciones por infringir los derechos de autor de productos de terceros.	Política de Uso aceptable. Registro de Indecopi del software SIEMPRESOFT ERP Registro de Indecopi del software SIEMPRESOFT OSE	Totalmente implementado
A.5.33	Protección de registros	Sí	Garantizar la protección y disponibilidad de los registros. RL, OC, RN, BP, RER	Disminuir la cantidad de registros sensibles afectados por la pérdida, destrucción, falsificación, acceso no autorizado y divulgación en el año.	Procedimiento para control de documentos y registros, Procedimientos Operativos para TI y de la Comunicación Política de clasificación de la información	Totalmente implementado
A.5.34	Privacidad y protección de la información de identificación personal (IIP)	Sí	Aplicar mecanismos de seguridad sobre el consentimiento de los datos personales de los clientes y trabajadores de Siempresoft; además de la exigencia en LEY DE PROTECCIÓN DE DATOS PERSONALES. RL, OC, RN, BP, RER	Reducir incumplimientos legales por falta de medidas técnicas y organizativas apropiadas para proteger la IIP en el año.	Banco de datos de clientes Banco de datos de trabajadores Política de privacidad Política de control de accesos Procedimientos Operativos para TI y de la Comunicación	Totalmente implementado

A.5.35	Revisión independiente de seguridad de la información	Sí	Garantizar la idoneidad, adecuación y eficacia continua de la organización para gestionar la seguridad de la información. RL, RN, BP, RER	Reducir la cantidad de incumplimientos en las auditorías fuera de las fechas programadas en el año.	Procedimiento para auditoría interna Auditoría de Ethical Hacking Auditoría de certificación realizada por SMC Slovenko A.S	Totalmente implementado
A.5.36	Cumplimiento con Políticas, reglas y normas de Seguridad de la información	Sí	Documento obligatorio que es necesario para la ISO 27001, y garantizar que el SGSI opere de acuerdo con las políticas y estándares implementados. RL, RN, BP, RER	Disminuir la cantidad de acciones correctivas generadas durante las revisiones periódicas en el año.	Revisiones periódicas	Implementado
A.5.37	Procedimientos operativos documentados	Sí	Garantizar el funcionamiento correcto y seguro de las instalaciones de procesamiento de información. RN, BP, RER	Mantener a disposición los procedimientos documentados de las actividades operativas que disminuya errores en el año.	Procedimientos operativos para tecnología de la información y de la comunicación Política de creación de copias de seguridad Procedimiento para el envío de Comprobantes Electrónicos Procedimiento para validación de comprobantes Procedimiento de despliegue de nueva versión del sistema Siempresoft Procedimiento para cambios críticos Procedimientos para pruebas de control de calidad Procedimientos para la replicación de errores en el ERP	Totalmente implementado
A.6	Controles de personal					

A.6.1	Selección	Sí	Garantizar la verificación y cumplimiento de los requerimientos del perfil y la documentación exigible del candidato y proveedor seleccionado. RL, OC, RN, RER	Recopilar información de todos los candidatos en la etapa de selección y verificar periódicamente la idoneidad continua del personal, según la importancia del rol en el año.	Procedimiento de selección, capacitación, inducción y evaluación del personal. Política de seguridad para proveedores.	Totalmente implementado
A.6.2	Términos y condiciones del empleo	Sí	Garantizar que el personal comprenda sus responsabilidades de seguridad de la información para el ejercicio de sus funciones. RL, OC, RN, RER	Mantener en todos los contratos las responsabilidades del personal y empresa con respecto a la seguridad de la información en el año.	Procedimiento de selección, capacitación, Inducción del personal Política de seguridad para proveedores. Reglamento Interno de Trabajo Perfiles de Puesto. Contrato con los trabajadores. Compromiso de no divulgación Declaración de Confidencialidad Proveedores Declaración de Aceptación de Documentos Código de conducta	Totalmente implementado
A.6.3	Toma de conciencia, educación y entrenamiento sobre la seguridad de la información	Sí	Garantizar que el personal y las partes interesadas conozcan y cumplan con sus responsabilidades de seguridad de la información, según sea relevante para la función del trabajo que desempeñen. OC, RN, BP, RER	Lograr la participación de todo el personal en los programas de capacitación y evaluación en temas de seguridad de la información siendo mayor al 95 % de la totalidad en el año.	Procedimiento de selección, capacitación, inducción y evaluación del personal. - 2.2 Competencia, Formación y Toma de Conciencia - d. Política de seguridad de la información Política de seguridad para proveedores Plan de Capacitación y Concienciación Procedimiento de medición del rendimiento del colaborador	Totalmente implementado

A.6.4	Proceso disciplinario	Sí	Asegurar que el personal comprenda las consecuencias de infringir la política de seguridad de la información y políticas específicas. RL, OC, RER	Disminuir la cantidad de sanciones originadas tras activar el proceso disciplinario en un 30% en el año.	Proceso disciplinario Reglamento interno	Totalmente implementado
A.6.5	Responsabilidades después del cese o cambio de empleo	Sí	Proteger los intereses de la empresa luego del cambio de puesto o la desvinculación. RL, OC, RN, BP, RER	Reducir contratos o acuerdos inexistentes o incompletos sobre la seguridad de la información después de la desvinculación con la empresa en el año.	Procedimiento para Terminación o cambio de puesto Política de seguridad para proveedores Política de uso aceptable 3.7. Devolución de activos a la finalización de un contrato Acta de devolución de materiales, suministros y accesos	Totalmente implementado
A.6.6	Acuerdos de confidencialidad o no divulgación	Sí	Control exigido para proteger, usar y divulgar la información de manera responsable y autorizada. RL, OC, RN, RER	Disminuir la cantidad de compromisos de no divulgación inexistentes en el área de RRHH en el año.	Compromiso de No Divulgación Declaración de confidencialidad de Proveedores	Totalmente implementado
A.6.7	Trabajo remoto	Sí	Garantizar la seguridad de la información cuando el personal realiza actividades de teletrabajo. RL, OC, RN, BP, RER	Reducir el número de incidentes de seguridad relacionados con las actividades de teletrabajo en un 25% durante el siguiente año.	Política sobre computación móvil y tele - trabajo – numeral 3.2. Reglas básicas Política de uso aceptable	Totalmente implementado
A.6.8	Reporte de eventos de seguridad de la información	Sí	Respaldar los registros de los eventos de seguridad de la información que son identificados y reportados por el personal. RL, RN, RER	Reducir la cantidad de reportes de incidentes de seguridad de la información que no cuentan con seguimiento en el año.	Procedimiento para gestión de incidentes Portal web de Soporte ERP	Totalmente implementado

A.7 Controles físicos						
A.7.1	Perímetros de seguridad física	Sí	Implementar perímetros de seguridad para evitar el acceso físico no autorizado y daño a la información y otros activos asociados. RL, RN, BP, RER	Reducir el número de áreas físicas desprotegidas en el año.	Procedimiento para trabajo en áreas seguras.	Totalmente implementado
A.7.2	Ingreso físico	Sí	Garantizar el acceso físico autorizado a la información y activos asociados. RL, OC, RER	Reducir la cantidad de controles de entrada físicos inexistentes o con fallas en el año.	Procedimiento para trabajo en áreas seguras.	Totalmente implementado
A.7.3	Asegurar oficinas, salas e instalaciones	Sí	Evitar el acceso físico no autorizado y daño a la información y activos asociados en oficinas, salas e instalaciones. RL, RN, RER	Impedir el acceso del público a las ubicaciones de instalación críticas en el año.	Procedimiento para trabajo en áreas seguras Las áreas internas cuentan con etiquetado en las puertas	Totalmente implementado
A.7.4	Supervisión de la seguridad física	Sí	Permitir detectar y disuadir el acceso físico no autorizado a las instalaciones u oficinas. RL, RN, BP, RER	Reducir la cantidad de incidentes en áreas físicas no incluidas en las revisiones periódicas en el año.	Procedimiento para trabajo en áreas seguras Política de control de accesos apartado 3.7. Revisiones periódicas de los derechos de acceso	Totalmente Implementado
A.7.5	Protección contra amenazas físicas y ambientales	Sí	Prevenir o reducir las consecuencias de incidentes originados por amenazas físicas y ambientales. RL, OC, RN, BP, RER	Disminuir la cantidad de amenazas no detectadas en el entorno físico y ambiental en el año.	Licencia de funcionamiento Certificado de INDECI Sistema de cámaras de vigilancia Caja fuerte Reglamento interno de SST	Totalmente implementado

A.7.6	Trabajo en áreas seguras	Sí	Proteger la información y activos en áreas seguras contra daños, las medidas de seguridad aplican a todo el personal. RL, RN, RER	Controlar apropiadamente el transporte y uso de equipamiento de computación móvil en oficina y teletrabajo en áreas seguras en el año.	Procedimientos para trabajo en áreas seguras	Totalmente implementado
A.7.7	Escritorio y pantalla limpios	Sí	Adoptar los mecanismos de protección para equipos desatendido y evitar riegos de acceso no autorizado. BP, RER	Reducir el riesgo de acceso no autorizado, pérdida, divulgación y daño a la información sensible en escritorios o pantallas dentro y fuera del horario laboral.	Política de pantalla y escritorio limpio Política sobre dispositivos móviles y teletrabajo apartado 3.2. Reglas básicas 4. Equipo Desatendido	Totalmente implementado
A.7.8	Ubicación y protección de los equipos	Sí	Reducir el riesgo de amenazas físicas y ambientales, y del acceso no autorizado y los daños. RN, BP, RER	Revisar periódicamente los controles para minimizar el riesgo de posibles amenazas físicas y ambientales en el año.	La oficina principal cuenta con Canaletas para el cableado de red, estabilizadores, cuchillas electromagnéticas, gabinetes, extintor, señalización de áreas seguras, aire acondicionado e instalación puesta a tierra.	Totalmente implementado
A.7.9	Seguridad de los activos fuera de las instalaciones	Sí	Evitar pérdidas, daños, robos y la interrupción de las operaciones ante la salida de equipos y dispositivos por áreas en constante demanda de visitas a clientes y labores de teletrabajo. RL, OC, BP, RER	Reducir la cantidad de dispositivos que se encuentren desprotegidos fuera de las instalaciones en el año.	Política sobre dispositivos móviles y teletrabajo 3.2. Reglas básicas, Política de Uso aceptable 3.5. Uso de activos fuera de las instalaciones, Declaración jurada - Salida del activo de información, Política de clasificación de la información 3.4. Manejo de información clasificada, Autorizaciones para retirar activos fuera de las instalaciones	Totalmente implementado

A.7.10	Medios de almacenamiento	Sí	Garantizar la manipulación autorizada de la información en los medios de almacenamiento. BP, RER	Disminuir el riesgo de daño, manipulación y divulgación de los medios de almacenamiento extraíble que contienen información sensible en el año.	Política de clasificación de la información 3.4. Manejo de información clasificada Política de eliminación y destrucción	Totalmente implementado
A.7.11	Servicios de suministro de apoyo		Evitar la pérdida, daño o interrupción de las operaciones debido a fallas o corte de energía en los servicios públicos. RL, OC, RN	Minimizar el tiempo de interrupción de las operaciones críticas por corte de energía en el año.	Política de recuperación ante desastres en oficina, UPS en los dispositivos de red de Siempresoft, Luces de emergencia, Red alterna (otro proveedor, red móvil)	Totalmente Implementado
A.7.12	Seguridad del cableado	Sí	Proteger el cableado que transporta energía e internet contra daño, robo, interferencia y la interferencia de las operaciones. RL, RN, BP, RER	Gestionar de manera adecuada los riesgos derivados de incidentes de cableado en el año.	Canaletas para cables de red, telefonía y de energía, Cajas de pase para conectores de alimentación y de video, Conectores de video	Totalmente implementado
A.7.13	Mantenimiento de equipos	Sí	Garantizar la disponibilidad, integridad y confidencialidad de la información contenida en los equipos y evitar interrupciones por falta de mantenimiento. RN, BP, RER	Reducir la cantidad de equipos dañados o inutilizados por falta de mantenimiento preventivo y correctivo en el año.	Procedimientos operativos para tecnología de la información y de la comunicación 3.15. Mantenimiento de los equipos de cómputo y otros, Revisión y mantenimiento del aire acondicionado	Totalmente implementado

A.7.14	Eliminación segura o reutilización de equipos	Sí	Proteger la información sensible de los equipos y soportes antes de ser eliminados o reutilizados, y evitar posibles fugas. RL, OC, RN, BP, RER	Reducir la cantidad de incidentes por no realizar correctamente el procedimiento de eliminación y destrucción en el año.	Política de Uso aceptable Política de eliminación y destrucción	Totalmente implementado
A.8	Controles tecnológicos					
A.8.1	Dispositivos terminales del usuario	Sí	Proteger la información almacenada, procesada y soportada en los dispositivos terminales de usuario. OC, RN	Reducir el número de incidentes de seguridad relacionados con los dispositivos móviles en un 25% durante el siguiente año.	Política sobre dispositivos móviles y tele - trabajo 3.2. Reglas básicas Declaración Jurada - Salida de activo de información. Política de control de acceso Política de uso aceptable 3. Uso aceptable de los activos de información Dispositivos AutoPilot inscritos y configurados en Intune Dispositivos administrados en Microsoft 365 Defender	Totalmente implementado
A.8.2	Derechos de acceso privilegiados	Sí	Garantizar que solo los usuarios autorizados y los servicios reciban derechos de acceso privilegiado. RN, BP, RER	Disminuir la realización de actividades con derechos de acceso privilegiado sin completar el proceso de autorización en el año.	Política de control de acceso 3.5. Gestión de privilegios, Roles en el portal de Azure 3.6. Gestión de cuentas de usuario 3.7. Revisiones periódicas de los derechos de acceso.	Totalmente implementado
A.8.3	Restricción de acceso a la información	Sí	Garantizar solo el acceso autorizado y restringir el acceso no autorizado a la información. RN, BP, RER	Reducir incidentes relacionados con el acceso no autorizado a la información por fallas en los controles de seguridad en el año.	Política de control de acceso Registro de accesos Política de clasificación de la información Inscripción y configuración de dispositivos en Microsoft 365 Defender (Reglas y Directivas)	Totalmente Implementado

A.8.4	Acceso al código fuente	Sí	Evitar la introducción de funciones, modificación, divulgación de los datos y copias no autorizadas del código fuente que perjudiquen el negocio. RL, RN, BP, RER	Reducir incidentes relacionados con la falta de control en la asignación de roles de acceso en los proyectos de código fuente en el año.	Política de control de acceso Registro de accesos	Totalmente implementado
A.8.5	Autenticación segura	Sí	Garantizar la autenticación segura de los usuarios y aplicaciones a los sistemas y servicios autorizados. RN, BP, RER	Controlar que el acceso a todas las aplicaciones sensibles cuente con un sistema de autenticación segura (SSO).	Política de claves, Política del uso de controles criptográficos	Totalmente implementado
A.8.6	Gestión de capacidad	Sí	Asegurar la capacidad requerida para los sistemas de información, recursos humanos y otros requisitos según la necesidad e importancia de los procesos comerciales. RL, RN, BP, RER	Establecer controles detectivos a los recursos claves para notificar problemas a tiempo en el año.	Procedimientos Operativos para TI y de la Comunicación 3.11. Gestión de la capacidad Política de gestión de cambios 3. Gestión de cambios, Procedimiento de selección, capacitación, Inducción del personal 2.1 SELECCIÓN Y RECLUTAMIENTO DEL PERSONAL 2.2 COMPETENCIA, FORMACIÓN Y TOMA DE CONCIENCIA (ítem b), Plan de capacitación y concienciación Procedimiento de logística	Totalmente implementado
A.8.7	Protección contra programas maliciosos (malware)	Sí	Garantizar que la información y activos estén protegidos contra el malware que causen alteración en los sistemas y aplicaciones. RL, RN, BP, RER	Lograr la puntuación de seguridad mayor de 75% en los puntos de conexión y recursos en la nube que detecten a tiempo vulnerabilidades que puedan ser explotadas por malware en el año.	Política de uso aceptable 3.9. Protección antivirus, Escaneo de antivirus por el portal Intune Evaluación de vulnerabilidades por el portal Microsoft 365 Defender Plan de capacitación y concienciación	Totalmente Implementado

A.8.8	Gestión de vulnerabilidades técnicas	Sí	Evitar la explotación de vulnerabilidades técnicas de los sistemas de información de SIEMPRESOFT evaluando la exposición y tomar las medidas adecuadas. RL, RN, BP, RER	Reducir la cantidad de vulnerabilidades detectadas en las pruebas de escaneo y penetración en un 30% en el año.	Procedimiento para cambios críticos Procedimientos Operativos para TI y de la Comunicación apartados 3.12. Gestión de amenazas y vulnerabilidades técnicas y 3.16. Pruebas de auditoría técnica a los sistemas de información Números de Grupos Especiales de Interés	Totalmente Implementado
A.8.9	Gestión de la configuración	Sí	Garantizar que el software, hardware, servicios y redes mantengan las configuraciones de seguridad correctas y no sufran alteraciones. RL, OC, RN, BP, RER	Reducir la cantidad de recursos afectados por cambios o falta de configuración de seguridad en el año.	Instructivo para buen uso de Team Explorer Procedimientos operativos para tecnología de la información y de la comunicación Arquitectura del servicio OSE, ERP, PSE. Planes de recuperación ante desastre en la plataforma Política de control de acceso 3.7. Revisiones periódicas de los derechos de acceso	y
A.8.10	Eliminación de información	Sí	Evitar la exposición de la información sensible y cumplir con los requisitos legales antes de reparar, donar o destruir la información contenida en medios de almacenamiento físicos y tecnológicos. RL, OC, RN, BP, RER	Reducir la cantidad de incidentes ocurridos por no eliminar adecuadamente la información sensible en el año.	Política de eliminación y destrucción	Totalmente implementado

A.8.11	Enmascaramiento de datos	Sí	Limitar la exposición de datos confidenciales ocultando la información real para el cumplimiento legal. RL, OC, RN, BP, RER	Reducir de información sensible de las bases de datos que no cuente con enmascaramiento en el año.	Estándares mínimos de seguridad apartado 7. ENCRIPCIÓN, Datos parcialmente ofuscados en la tabla Directorio en las BDs Política de clasificación de la información apartado 3.3 Etiquetado de la información: Inventario de dispositivos, Base de datos SQL Azure	Implementado
A.8.12	Prevención de fuga de datos	Sí	Disponer de recursos tecnológicos para respaldar la información y las copias de seguridad puedan ser probados para permitir la recuperación ante la pérdida de datos y evitar incumplimientos RL, OC, RN, BP, RER	Reducir la cantidad de incidentes de fuga de información fuera de la organización en el año.	Política de clasificación de la información 3.2. Clasificación de la información Política de control de acceso 3.7. Revisiones periódicas de los derechos de acceso Administración centralizada de dispositivos con directivas de acceso condicional Política del uso de controles criptográficos Compromiso de no divulgación, Declaración jurada – salida de activo de información, Declaración de aceptación de documento sgsi Política de protección de datos personales	Implementado
A.8.13	Copia de seguridad de la información	Sí	Disponer de recursos tecnológicos para respaldar la información y que estas sean probadas con seguridad para permitir su recuperación ante la pérdida de datos. RL, OC, RN, BP, RER	Reducir la cantidad de copias de seguridad fallidas o no generadas en el año.	Política de creación de copias de seguridad, Política de uso aceptable	Totalmente implementado

A.8.14	Redundancia de las instalaciones de procesamiento de información	Sí	Asegurar el funcionamiento continuo del sistema SIEMPRESOFT ERP y servicio SIEMPRESOFT OSE con suficiente redundancia para cumplir con los requisitos para la disponibilidad de los servicios del negocio. RL, OC, RN, BP, RER	Garantizar que los componentes redundantes y las instalaciones de procesamiento de información cuenten con el mismo nivel de seguridad que las primarias en el año.	Plan de recuperación ante desastres en Oficina, Plan de recuperación ante desastres en Plataforma, Política sobre dispositivos móviles y de tele – trabajo	Totalmente implementado
A.8.15	Registro	Sí	Almacenar logs que registren errores, excepciones u otros eventos que sirvan de apoyo a las investigaciones de incidentes de seguridad de la información. RL, OC, RN, BP, RER	Reducir la manipulación o pérdida de los registros de eventos de seguridad de los sistemas críticos en el año.	Procedimientos Operativos para TI y de la Comunicación 3.10 Supervisión del sistema, 3.14 Gestión de la Configuración Política de control de acceso 3.7. Revisiones periódicas	Totalmente implementado
A.8.16	Actividades de monitoreo	Sí	Detectar comportamientos anómalos y posibles incidentes de seguridad de la información para tomar acciones apropiadas. RL, OC, RN, BP, RER	Disminuir la cantidad de incumplimiento de las actividades de monitoreo no realizadas a los servicios y sistemas en el año.	Procedimientos Operativos para TI y de la Comunicación 3.10 Supervisión del sistema, 3.14 Gestión de la Configuración Política de control de acceso 3.7. Revisiones periódicas	Totalmente implementado

A.8.17	Sincronización de reloj	Sí	Exigido para garantizar la exactitud de los registros de auditoría, cumplimiento regulatorio ante SUNAT, acceso al sistema ERP y en casos disciplinarios. Los relojes están sincronizados a una zona horaria. RL, OC, RN, RER	Reducir los riesgos de alteración en el cambio de la zona horaria que impliquen errores en la generación de xml, registro de auditorías, acceso al ERP y reportes en el año.	Procedimientos Operativos para TI y de la Comunicación 3.10. Supervisión del sistema.	Totalmente implementado
A.8.18	Uso de programas de utilidad privilegiados	Sí	Limitar el uso de los programas de utilidad solo a usuarios autorizados para evitar daños en el sistema y controles de aplicaciones. RN, BP, RER	Reducir la cantidad de dispositivos inoperativos o con fallas por cambios no autorizados en el sistema en el año.	Política de control de acceso 3.5. Gestión de privilegios Accesos por roles en Azure (Privileged Identity Management)	Totalmente implementado
A.8.19	Instalación de software en sistemas operativos	Sí	Garantizar la integridad de los sistemas operativos y evitar la explotación de vulnerabilidades técnicas por usuarios no autorizados. RL, OC, RN, BP, RER	Reducir equipos con fallas, errores o expuestos a vulnerabilidades por falta de actualización en el sistema operativo en el año.	Política de control de accesos Política de Uso aceptable 3.4 Actividades permitidas (Autorizaciones para instalación de software externo) Procedimientos operativos para tecnología de la información y de la comunicación 3.2. Gestión de cambios Instructivo de Despliegue de nueva versión del Sistema SIEMPRESOFT ERP Actualización del SO desde Intune Política de desarrollo seguro 3.4. Requerimientos de seguridad, Estándar mínimos de seguridad apartado 3. USO DE LIBRERÍAS EXTERNAS	Totalmente implementado

A.8.20	Seguridad de redes	Sí	Administrar los dispositivos de red para proteger la información en las redes locales y públicas. RL, OC, RN, BP, RER	Denegar el acceso a las redes de Siempresoft a todo equipo y dispositivo que no esté autorizado al 100% en el año.	Política de control de acceso Política de uso aceptable apartado 3.12. Uso de internet Procedimientos operativos para tecnología de la información y de la comunicación apartados 3.5. Gestión de seguridad de red y 3.6. Servicios de red	Totalmente implementado
A.8.21	Seguridad de servicios de red	Sí	Garantizar las medidas de seguridad en el uso de los servicios de red al seleccionar el proveedor de internet. RL, OC, RN, BP, RER	Reducir vulnerabilidades en la seguridad de la red por malas configuraciones en el año.	Procedimientos operativos para tecnología de la información y de la comunicación 3.5. Servicios de red Política de desarrollo seguro apartado 3.5. Requerimientos de seguridad relacionados con redes públicas Política de seguridad para proveedores Router no configurable (red inalámbrica oculta) Configuraciones de seguridad en firewall en la nube de Intune y Microsoft Defender	Totalmente implementado
A.8.22	Segregación de redes	Sí	Dividir la red para limitar la seguridad y controlar el tráfico entre ellos en función de las necesidades del negocio. RN, BP, RER	Reducir incidentes de rendimiento, propagación de malware o acceso no autorizado a las redes de Siempresoft en el año.	Procedimientos operativos para tecnología de la información y de la comunicación apartado 3.5. Gestión de seguridad de red	Totalmente implementado
A.8.23	Filtrado de la web	Sí	Proteger los equipos y sistemas contra el malware y evitar el acceso a recursos web no autorizados o ilegales. RN, BP, RER	Mantener actualizado el filtrado web que evite ataques de phishing por acceso a páginas dañinas en el año.	Directivas de amenazas, Configuración para Puntos de conexión Filtrado web Perfiles de configuración/Microsoft Edge Policy Política de uso aceptable 3.4. Actividades permitidas y 3.5. Actividades prohibidas	Totalmente Implementado

A.8.24	Uso de criptografía	Sí	Exigido por SUNAT para gestionar y proteger las claves criptográficas de facturación electrónica y en el proceso de validación de comprobantes OSE. RL, OC, RN, BP, RER	Reducir la cantidad de incidentes relacionados con los certificados y claves criptográficas en el año.	Política del uso de controles criptográficos	Totalmente Implementado
A.8.25	Ciclo de vida del desarrollo seguro	Sí	Garantizar la seguridad de la información dentro de todo el ciclo de vida de desarrollo seguro de software. RN, BP, RER	Reducir incidencias relacionadas con incumplimientos en la seguridad del código fuente en todo el ciclo de vida del software en el año.	Manual del ciclo de vida de software Estándares de desarrollo Política de desarrollo seguro Estándares mínimos de seguridad	Totalmente implementado
A.8.26	Requisitos de seguridad de la aplicación	Sí	Garantizar el cumplimiento de todos los requisitos de seguridad de la información en el desarrollo del software. RL, OC, RN, BP, RER	Reducir el número de incumplimientos de los estándares de desarrollo seguro en los sistemas de información de Siempresoft en el año.	Estándares mínimos de seguridad Política de desarrollo seguro 3.1. Evaluación de riesgos para el proceso de desarrollo Plan de recuperación ante desastres en la plataforma Procedimientos operativos para tecnología de la información y de la comunicación 3.10. Supervisión del sistema Manual técnico del sistema SIEMPRESOFT OSE Lista de requisitos legales normativos contractuales, Política de privacidad	Totalmente Implementado

A.8.27	Arquitectura de sistemas seguros y principios de ingeniería	Sí	Mantener los principios de ingeniería segura en todas las capas de arquitectura de los sistemas de Siempresoft. RL, OC, RN, BP, RER	Implementar una o más tecnologías que detecte riesgos de seguridad frente a patrones de ataque conocidos en el año.	Estándares de desarrollo Política de desarrollo seguro Estándares mínimos de seguridad Procedimientos Operativos para TI y de la Comunicación, Controles de auditoría de sistemas de información	Totalmente implementado
A.8.28	Codificación segura	Sí	Garantizar que los sistemas de Siempresoft cumplan con los principios de codificación, reduciendo así la cantidad de posibles vulnerabilidades de seguridad. RL, OC, RN, BP, RER	*Realizar un análisis de los errores de programación más comunes y documentar cuantos han sido mitigados en un 20% en el año. *Implementar el Estándar de verificación de seguridad de aplicaciones OWASP en los proyectos de desarrollo en un 70% en el año.	Estándares de desarrollo Estándares mínimos de seguridad Política de desarrollo seguro Procedimiento para programación de requerimientos Procedimiento para análisis de requerimientos Procedimiento para cambios críticos Procedimiento Para Pruebas de Control de Calidad Procedimiento para replicación de errores en el ERP Inventario de librerías externas autorizadas Política de control de acceso	Totalmente implementado
A.8.29	Pruebas de seguridad en desarrollo y aceptación	Sí	Validar el cumplimiento de los requisitos de seguridad cuando el código es implementado en el entorno de producción. OC, RN, BP, RER	Ejecutar varios programas de revisión de código, escaneo de vulnerabilidades y pruebas de penetración en el año.	Política de desarrollo seguro Estándares mínimos de seguridad Procedimiento Para Pruebas de Control de Calidad Procedimiento para replicación de errores en el ERP	Totalmente implementado
A.8.30	Desarrollo subcontratado	No	No se encuentra aplicable para el alcance establecido.			

A.8.31	Separación de los entornos de desarrollo, prueba y producción	Sí	Proteger el entorno de producción y los datos y mantener separados de las actividades de desarrollo y prueba. RL, RN, BP, RER	Reducir la cantidad de incidentes de seguridad de la información en los ambientes de producción por pruebas directas en el año.	Política de desarrollo seguro 3.2. Asegurar el ambiente físico de desarrollo, 3.7. Protección de datos de prueba Procedimiento para programación de requerimientos Instructivo para buen uso de Team Explorer, Instructivo de Despliegue de nueva versión del Sistema SIEMPRESOFT ERP Procedimiento Para Pruebas de Control de Calidad Procedimiento para cambios críticos	Totalmente implementados
A.8.32	Gestión de cambios	Sí	Preservar la seguridad de la información al realizar cambios en la infraestructura tecnológica y los sistemas de Siempresoft. RL, OC, RN, BP, RER	Reducir la cantidad de cambios de infraestructura y sistemas en el entorno de producción sin pruebas exhaustivas que generen impactos negativos en el año.	Procedimientos Operativos para TI y de la Comunicación 3.2. Gestión de cambios Procedimiento para análisis de requerimientos Procedimiento para cambios críticos Política de gestión del cambio Plan de recuperación ante desastres en la plataforma Plan de recuperación ante desastres en oficina	Totalmente implementado
A.8.33	Información de las pruebas	Sí	Garantizar la relevancia de las pruebas y protección de la información utilizada para las pruebas. RL, OC, RN, BP, RER	Evitar el uso no autorizado de la información de prueba en el año.	Procedimiento para pruebas de control de calidad Procedimiento para replicación de errores en el ERP Política de desarrollo seguro 3.6. Verificación y prueba de la implementación de requerimientos de seguridad. Política de creación de copias de seguridad 3.4. Prueba de las copias de seguridad	Totalmente implementado

A.8.34	Protección de los sistemas de información durante las pruebas de auditoría	Sí	Minimizar el impacto de la auditoría en las actividades comerciales. RL, OC, RN, BP, RER	Reducir la cantidad de incidentes que surgen de las pruebas de auditoría a los sistemas de Siempresoft en el año.	Procedimiento para auditoría interna Política de control de acceso 3.4. Reglas para el control de accesos Procedimientos Operativos para TI y de la Comunicación	Totalmente implementado
--------	--	----	--	---	--	-------------------------

4. Aceptación de los riesgos residuales

Debido a que no se han podido reducir todos los riesgos en el proceso de gestión de riesgos, por medio de la presente se aceptan todos los siguientes riesgos residuales:

1. Todos los riesgos con valor Muy bajo, Bajo y Medio.

5. Validez y gestión de documentos

Este documento es válido hasta el 21/11/2026.

El propietario del presente documento es el Oficial de Seguridad de la Información, que debe verificar y, si es necesario, actualizar el documento por lo menos una vez al año e inmediatamente después de las revisiones de evaluación de riesgos.